Authorization and Access Control Models

Introduction

Authorization is a fundamental concept in information security, determining what actions a subject (such as a user, system, or process) can perform on an object (such as data, applications, or resources). By assigning appropriate permissions and privileges, organizations ensure that only authorized entities can access or manipulate sensitive assets, protecting them from misuse or unauthorized access. This document explores the key principles of authorization and the primary access control models used to enforce it.

Core Concepts in Authorization

Subjects and Objects

Subject: The active entity requesting access (e.g., user, process, or application).

Object: The passive entity being accessed (e.g., file, database, system resource).

Permissions, Rights, and Privileges

Permissions: Specific access levels granted to a subject (e.g., read, write).

Rights: Higher-level actions (e.g., execute, delete).

Privileges: The combination of permissions and rights, defining the overall scope of what a subject can do with an object.

Access Control Lists (ACLs)

- ACLs are lists specifying which subjects can perform which actions on specific objects.
- Serve as the mechanism for enforcing access control policies across systems.

CYVITRIX LEARNING

Access Control Models

1. Mandatory Access Control (MAC)

Definition: Access permissions are centrally determined based on security labels (e.g., confidential, secret, top secret).

Characteristics:

- Subjects cannot alter permissions; control is enforced strictly by the system.
- Common in government and military environments where security is paramount.

Example: The Bell-LaPadula model restricts subjects to accessing only data at or below their clearance level.

Advantages:

- Ensures strict adherence to security policies.
- Minimizes risk of unauthorized access.

Limitations:

- Inflexible, as users cannot change their own permissions.

2. Discretionary Access Control (DAC)

Definition: Data owners have the authority to determine who can access their resources and what actions they can perform.

Characteristics:

- Users can share or modify permissions for their data.
- Common in corporate environments requiring flexibility.

Example: A user who owns a file can grant read/write access to others.

Advantages:

- Offers autonomy and flexibility to users.

Risks:

- Users may inadvertently grant access to unauthorized individuals, potentially leading to data exposure.
- Requires policies and oversight to mitigate these risks.

CYVITRIX LEARNING

3. Role-Based Access Control (RBAC)

Definition: Permissions are assigned to roles, and users are assigned to these roles.

Characteristics:

- Users inherit permissions based on their assigned roles (e.g., administrator, user, manager).
- Simplifies management by grouping permissions.

Example: A database administrator role includes read, write, and delete permissions; a regular user role includes read-only access.

Advantages:

- Streamlines permission management, especially in large organizations.
- Ensures consistency and scalability (e.g., via Active Directory security groups).

4. Rule-Based Access Control (RuleBAC)

Definition: Access is granted or denied based on predefined rules or conditions, often in addition to other models.

Characteristics:

- Rules can include attributes like time, location, device type, etc.
- Enables dynamic and context-aware access controls.

Example: Network administrators can modify firewalls only during business hours; access to certain systems is restricted to specific IP ranges.

Advantages:

- Provides granular, situational access control.
- Often layered on top of RBAC for enhanced security.

Hybrid and Layered Approaches

- Organizations may combine multiple access control models to address diverse security requirements.

Example: A government agency uses MAC for classified data and RBAC within each classification.

Example: A corporation employs DAC for general file sharing but overlays RuleBAC conditions for sensitive data during off-hours.

CYVITRIX LEARNING

Benefits: Leverages strengths of each model, balancing flexibility, security, and operational efficiency.

Summary

Authorization is essential for aligning access control decisions with organizational policies and security requirements. Understanding the strengths and limitations of each access control model empowers organizations to:

- Select the most suitable model(s) for their needs.
- Protect sensitive data and resources.
- Prevent unauthorized access.
- Ensure robust, adaptable security policies.

Mastering these models—Mandatory Access Control (MAC), Discretionary Access Control (DAC), Role-Based Access Control (RBAC), and Rule-Based Access Control (RuleBAC)—enables security professionals to design and implement secure, efficient access management systems that meet the dynamic needs of modern organizations.

CYVITRIX LEARNING

Authorization and Access Control Models Quiz

Questions

1. What is the primary purpose of authorization in an information system?

A) To encrypt data in transit

B) To determine what a subject can do with an object

C) To monitor network traffic

D) To authenticate user identities

B _____

2. In the context of access control, what does the term "subject" refer to?

A) The file being accessed

B) The system's hardware

C) The entity requesting access

D) The access control policy

C _____

3. Which access control model is characterized by centrally determined permissions and security labels such as “confidential” or “top secret”?

A) Discretionary Access Control (DAC)

B) Role Based Access Control (RBAC)

C) Mandatory Access Control (MAC)

D) Rule Based Access Control (RuleBAC)

C _____

4. What is the main advantage of Discretionary Access Control (DAC)?

A) Centralized, strict control over all permissions

CYVITRIX LEARNING

B) Flexibility for data owners to manage access

C) Automatic role assignment

D) Enforcement of rules based on time and location

B

5. What is a key risk associated with Discretionary Access Control (DAC)?

A) Excessive centralization

B) Inability to assign roles

C) Users may inadvertently grant access to unauthorized individuals

D) Lack of security labels

C

6. In Role Based Access Control (RBAC), how are permissions typically assigned?

A) Directly to individual users

B) Based on user roles

C) By the owner of each file

D) By device type

B

7. Which access control model allows permissions to be enforced by rules such as time of day or device used?

A) Mandatory Access Control (MAC)

B) Role Based Access Control (RBAC)

C) Rule Based Access Control (RuleBAC)

D) Discretionary Access Control (DAC)

C

8. Access Control Lists (ACLs) are primarily used to:

A) Encrypt user passwords

B) Specify which subjects can perform which actions on objects

C) Define network segmentation

CYVITRIX LEARNING

D) Assign users to hardware resources

B

9. Which access control model is most commonly used in military and government environments?

A) DAC

B) MAC

C) RBAC

D) RuleBAC

B

10. What is an "object" in the context of authorization?

A) The entity requesting access

B) The passive entity being accessed

C) The security administrator

D) The network protocol

B

11. Which model is best suited for large organizations with dynamic user groups and needs for scalable access management?

A) MAC

B) DAC

C) RBAC

D) RuleBAC

C

12. A company wants to allow users to share files but also restrict access to sensitive data outside business hours. Which approach is most appropriate?

A) Only DAC

B) Only RBAC

C) Hybrid of DAC and RuleBAC

D) Only MAC

CYVITRIX LEARNING

C

13. In the Bell-LaPadula model, what rule is strictly enforced?

A) No write down

B) No read up

C) Both no read up and no write down

D) No delete

C

14. Which of the following best describes "privileges" in authorization?

A) Specific access levels like read or write

B) Higher-level actions such as execute or delete

C) The combination of permissions and rights defining the scope of actions

D) The process of authenticating a user

C

15. Rule Based Access Control (RuleBAC) is particularly useful for:

A) Assigning static permissions

B) Providing dynamic, context-aware access decisions

C) Allowing users to manage their own files

D) Centralizing all permissions

B

16. Which of the following is a potential weakness of RBAC if not managed properly?

A) Excessive user autonomy

B) Stale or unused roles accumulating over time

C) Inability to assign permissions to groups

D) Lack of predefined rules

B

17. What is the main purpose of combining multiple access control models in a hybrid approach?

CYVITRIX LEARNING

A) To increase system complexity

B) To balance flexibility, security, and operational efficiency

C) To reduce the need for user authentication

D) To eliminate the need for access control lists

B

18. Which model would be least suitable for an environment where users need full autonomy over their own data?

A) DAC

B) RBAC

C) MAC

D) RuleBAC

C

19. What is the primary function of rights in authorization?

A) To define specific access levels

B) To execute or delete objects

C) To encompass higher-level actions granted to a subject

D) To identify objects in the system

C

20. What is a common tool or mechanism for enforcing authorization policies?

A) Digital certificates

B) Access Control Lists (ACLs)

C) Network routers

D) Encryption keys

CYVITRIX LEARNING

Answers and Explanations

1. **Answer: B** - Explanation: Authorization specifies what actions a subject can perform on an object, safeguarding assets from misuse.

---

2. **Answer: C** - Explanation: A subject is the active entity (like a user or process) requesting access to an object.

---

3. **Answer: C** - Explanation: MAC uses centrally controlled permissions and security labels, common in high-security settings.

---

4. **Answer: B** - Explanation: DAC allows data owners to control and share their resources as needed.

---

5. **Answer: C** - Explanation: DAC's flexibility means users can mistakenly grant access to unauthorized individuals.

---

6. **Answer: B** - Explanation: RBAC assigns permissions to roles, which are then assigned to users, simplifying management.

---

7. **Answer: C** - Explanation: RuleBAC enforces access based on rules like time, device, or location attributes.

---

8. **Answer: B** - Explanation: ACLs list which subjects can do which actions on particular objects.

---

9. **Answer: B** - Explanation: MAC is preferred in environments requiring strict, centralized security such as government and military.

---

10. **Answer: B** - Explanation: An object is the passive entity (like a file or resource) being accessed.

CYVITRIX LEARNING

---

11. **Answer: C** - Explanation: RBAC is ideal for large, dynamic organizations due to its scalable role-based permission assignment.

---

12. **Answer: C** - Explanation: Combining DAC for sharing and RuleBAC for time-based restrictions addresses both needs.

---

13. **Answer: C** - Explanation: Bell-LaPadula enforces both "no read up" and "no write down" to protect classified data.

---

14. **Answer: C** - Explanation: Privileges combine permissions and rights to define the full scope of allowed actions.

---

15. **Answer: B** - Explanation: RuleBAC provides flexibility through context-aware (e.g., time/location) access controls.

---

16. **Answer: B** - Explanation: Without proper management, unused or outdated roles may persist in RBAC, increasing risk.

---

17. **Answer: B** - Explanation: Hybrid models leverage strengths of each approach for balanced security and flexibility.

---

18. **Answer: C** - Explanation: MAC is highly centralized and restrictive, not suitable for user autonomy.

---

19. **Answer: C** - Explanation: Rights enable higher-level actions, like executing or deleting, granted to a subject.

---

20. **Answer: B** - Explanation: ACLs are a common mechanism for enforcing who can access what in a system.

CYVITRIX LEARNING